Designing for Ransomware Resilience

VMware Cloud Foundation 9.1

August 2026

vmware by Broadcom

Table of Contents

Disclaimer....4

Executive Summary....5

Design Responsibilities....6

Scope and Product Boundaries....7

Threat Model and Design Objectives....8

- Ransomware Is an Intrusion, Not Just Encryption 8
- AI Changes Pace More Than Architecture 8
- Zero Trust and Platform Trust Solve Different Problems 8
- Design Across the Full Ransomware Lifecycle 8

Choose a Management-Plane Topology....10

- Compare the Choices 10
- Make the Boundary Real 11
- Implementation and Validation 11

Secure the Platform Foundation....12

- Hardware and Physical Controls 12
- Establish Host Trust Without Overstating It 13
- Separate Networks by Function and Consequence 14
- Choose Link Resilience Deliberately 15
- Design Administrative Identity for Survivable Access 16
- Keep Core Dependencies Available and Trustworthy 17

Design Workloads for Containment and Recovery....20

- Classify Workloads Before Selecting Tools 20
- Map the Application Dependency Group 20
- Segment Workloads Around Application Intent 21
- Make the Workload Easier to Rebuild 21

Detect, Investigate, and Contain....23

- Combine Signals Across Control Planes 23
- Design the Investigation Path Before the Incident 24
- Give Containment Actions Owners and Limits 24
- Use a Decision-Based Response Runbook 25

Recover and Validate....27

- Distinguish Four Different Outcomes 27
- Name the Isolation You Actually Have 27

Choose More Than One Kind of Recovery Copy 28
Treat Immutability as a Scoped Property 29
Understand vSAN Data Protection Boundaries 29
Place the Recovery Control Plane Outside Its Own Failure 30
Select a Recovery-Site Operating Pattern 30
Build the Isolated Recovery Environment as an Operating Zone 31
Recover in an Order That Protects Trust 31
Validate the Recovery Method, Not Only the Restore Job 32
Test the Design 33
Minimum Acceptance Tests 34
Owner-Based Design Checklist 35
Governance and Business Continuity Owners 35
Platform Team 35
Network and Security-Policy Team 35
Identity Team 35
Core Infrastructure Services Team 35
Key and Cryptography Owners 36
Backup and Recovery Team 36
Security Operations and Incident Response Team 36
Application and Data Owners 36
Glossary 37
Notes and Sources 38

Disclaimer

This document is intended to provide general guidance for organizations that are considering Broadcom solutions. The information contained in this document is for educational and informational purposes only. This document is not intended to provide advice and is provided "AS IS." Broadcom makes no claims, promises, or guarantees about the accuracy, completeness, or adequacy of the information contained herein. Organizations should engage appropriate legal, business, technical, and audit expertise within their specific organization for review of requirements and effectiveness of implementations.

Executive Summary

Ransomware is the visible end of a longer intrusion. Attackers gain a foothold through stolen credentials, social engineering, or vulnerable services. They move toward privileged systems, copy data, weaken recovery options, and may encrypt systems only after those steps are complete. Some campaigns rely on data theft and extortion without encrypting anything. The design problem is therefore larger than stopping a payload.[1]

Virtualization management and backup systems deserve special attention because they have broad control. An administrator who can change VMware vCenter, VMware ESX, network policy, encryption keys, or backup retention can affect many workloads in one action. Ransomware families have included hypervisor-specific variants, and the 2023 ESXiArgs activity affected vulnerable systems exposed to the internet.[2][3] Treat the management plane, recovery control plane, and their administrative identities as high-consequence infrastructure.

VMware Cloud Foundation (VCF) gives architects useful building blocks, but the blocks do not make the decisions. A resilient design still has to answer practical questions:

- Which systems share a failure domain with the management plane?
- Who can administer infrastructure identity, network policy, keys, logs, snapshots, and backups?
- Which services must survive when the primary site and corporate identity system are unavailable?
- How far back can the organization recover if an intrusion was present before anyone noticed?
- Where can candidate systems be started without trusting the production network?
- What evidence proves that a recovered application is safe enough to return to service?

The main recommendation is to design for containment and recovery as deliberately as for availability. Separate high-consequence control planes where the risk justifies the cost. Restrict and monitor management paths. Preserve more than one kind of recovery copy. Keep at least one copy outside the ordinary production trust boundary. Test recovery with compromised credentials and a hostile production network, not only with a failed server or site.

No architecture defeats every ransomware campaign. These choices reduce shared paths, create places to observe and contain activity, and give the recovery team more trustworthy options.

Design Responsibilities

Ransomware-resilience design requires shared ownership. Security owners define threat assumptions and containment authority. Platform and network teams design the management and workload boundaries. Identity owners define authentication, authorization, and emergency access. Application owners describe dependency order and acceptable data loss. Backup and business-continuity owners select recovery patterns and approve return to service. A design is incomplete if any of those decisions exists only inside one team's runbook.

Scope and Product Boundaries

VCF 9.1 scope is limited to generally available functionality documented as of August 28, 2026. Roadmap and technical-preview material are excluded. Confirm behavior against the release notes, interoperability matrices, entitlements, and patch documentation for the builds you plan to deploy.[4]

Security architects, virtualization administrators, infrastructure engineers, network architects, identity architects, backup and recovery teams, and business-continuity owners must coordinate the design and operating decisions. Use the current VCF Security Configuration Guide for configuration baselines and control settings.[5]

The design scope includes VCF 9.1 core and three separately licensed Advanced Services where they affect a ransomware design decision. Entitlements can vary by contract, so confirm them before treating a capability as available.

Product or Service	Design Role	Boundary to Keep Clear
VCF 9.1 core	Compute, storage, NSX networking and overlay, lifecycle, identity integration, VCF Operations, VCF Log Management, host trust, encryption, and native vSAN data protection	Base NSX networking is not the same entitlement as vDefend firewall and threat-prevention functions.
VMware vDefend	Distributed and gateway firewalling, microsegmentation, IDS/IPS, and optional network threat-analysis functions	It is a separately licensed advanced service. Capability depends on the purchased edition and deployed Security Services Platform components.
VMware Avi Load Balancer	Application delivery, load balancing, and optional web application firewall (WAF) inspection	It is a separately licensed advanced service. A WAF filters HTTP/S application traffic; it is not a general ransomware control.
VCF Protection and Recovery	Disaster-recovery orchestration, replication workflows, and cyber-recovery workflows with isolated validation options	It is a separately licensed advanced service. Topology, target, retention, analysis, and entitlement determine the available recovery functions.

The VCF 9.1 FAQ identifies Avi Load Balancer, vDefend, and VMware Live Recovery, now named VCF Protection and Recovery, as separately licensed Advanced Services.[6][7] VCF Advanced Cyber Compliance is not covered. If a design depends on that service, document the specific entitlement and component boundary separately.

Threat Model and Design Objectives

Ransomware Is an Intrusion, Not Just Encryption

Ransomware is malware used to deny access to data, often by encryption, while attackers demand payment. Modern extortion can also include theft and threatened publication of data. The encryption event is obvious. The activity before it often is not.

Attackers may enter through phishing, stolen credentials, exposed remote access, or an unpatched internet-facing service. They establish persistence, move laterally, obtain higher privileges, collect data, and look for systems that would let the organization recover. CISA recommends offline encrypted backups and regular restore tests because many ransomware variants try to delete or encrypt accessible backups.[8]

The virtualization platform is part of that threat model. CISA and the FBI reported that ESXiArgs activity affected internet-exposed ESX systems with vulnerable services. Their guidance was to remove public exposure, patch, disable the unneeded SLP service, and maintain offline backups.[3] A separate CISA advisory documented a Hive ransomware variant for ESX.[2] These examples do not mean that every campaign uses the same path. They show why hypervisor and management interfaces should not be treated as ordinary administration tools.

Many attacks begin with credentials that work. The FBI has documented criminals impersonating employees when contacting IT and help-desk staff to change login information.[9] Monitoring only failed logins misses part of that activity. Watch successful but unusual authentication, new MFA enrollment, new API clients, privilege changes, recovery-code use, and changes made with valid administrative tools.

AI Changes Pace More Than Architecture

AI can make phishing text more believable and cheaper to produce. It can also create voice or video impersonations for social engineering. The FBI has documented both uses.[10] In June 2026, the Five Eyes cyber security agencies said that AI accelerates the speed, scale, and sophistication of cyber threats. They also said that risk assumptions can change in months rather than years.[11]

The practical response remains familiar. An AI-assisted intrusion still needs access, privileges, network paths, command channels, data paths, and a way to affect systems. Phishing-resistant multifactor authentication (MFA), restrictive administrative paths, rapid patching, egress monitoring, independent logs, and tested recovery continue to address those needs. Review the threat assumptions more frequently, but do not replace durable controls with an "AI security" label.

Zero Trust and Platform Trust Solve Different Problems

Zero Trust does not mean that nothing can ever be trusted. In NIST's model, no implicit trust is granted solely because an account or asset is internal or owned by the organization. Authentication and authorization happen before a session reaches a resource.[12]

That access model is different from platform-integrity mechanisms. Secure Boot, signed software components, Trusted Platform Modules (TPMs), and host attestation help establish what code and configuration a host started with. They do not decide whether an administrator should access vCenter, and they do not scan guest data for ransomware. A useful design applies both ideas:

- Make access decisions from identity, role, device, context, and policy rather than network location alone.
- Use platform trust to detect unexpected boot and configuration states.
- Assume that a valid account, trusted endpoint, or signed component can still be misused.
- Record enough independent evidence to investigate when a trusted path behaves unexpectedly.

Design Across the Full Ransomware Lifecycle

NIST IR 8374 Revision 1 maps ransomware risk to the six Cybersecurity Framework 2.0 functions: Govern, Identify, Protect, Detect, Respond, and Recover.[1] The previous edition of IR 8374 has been withdrawn, so do not reuse its five-function model as current CSF 2.0 guidance.

Function	Design Question for VCF
Govern	Who owns risk acceptance, containment authority, recovery priorities, evidence, and the return-to-service decision?
Identify	Which management systems, identities, dependencies, data sets, and workloads could create the largest shared impact?
Protect	Which access, segmentation, hardening, patching, encryption, and copy controls reduce available attack paths?
Detect	Which identity, network, workload, platform, and backup signals reveal misuse before broad damage?
Respond	Who can quarantine systems, protect evidence, revoke access, and keep the response channel available?
Recover	Which copy and environment can restore the required business service to a sufficiently trusted state?

Recommendation: Write one threat statement that the technical design can test. A useful starting point is: "Assume that one workload and one ordinary enterprise administrator account are compromised, and that the attacker can observe the production network." Add stronger assumptions for backup administrators, vCenter administrators, identity administrators, and physical access where the business impact warrants them.

Choose a Management-Plane Topology

The first major choice is whether management systems and customer workloads share a cluster or use separate clusters. A consolidated footprint can be reasonable for a small environment. A separated management domain creates more opportunities for independent controls and recovery. Those benefits depend on the surrounding networks, storage, identity, keys, and administration.

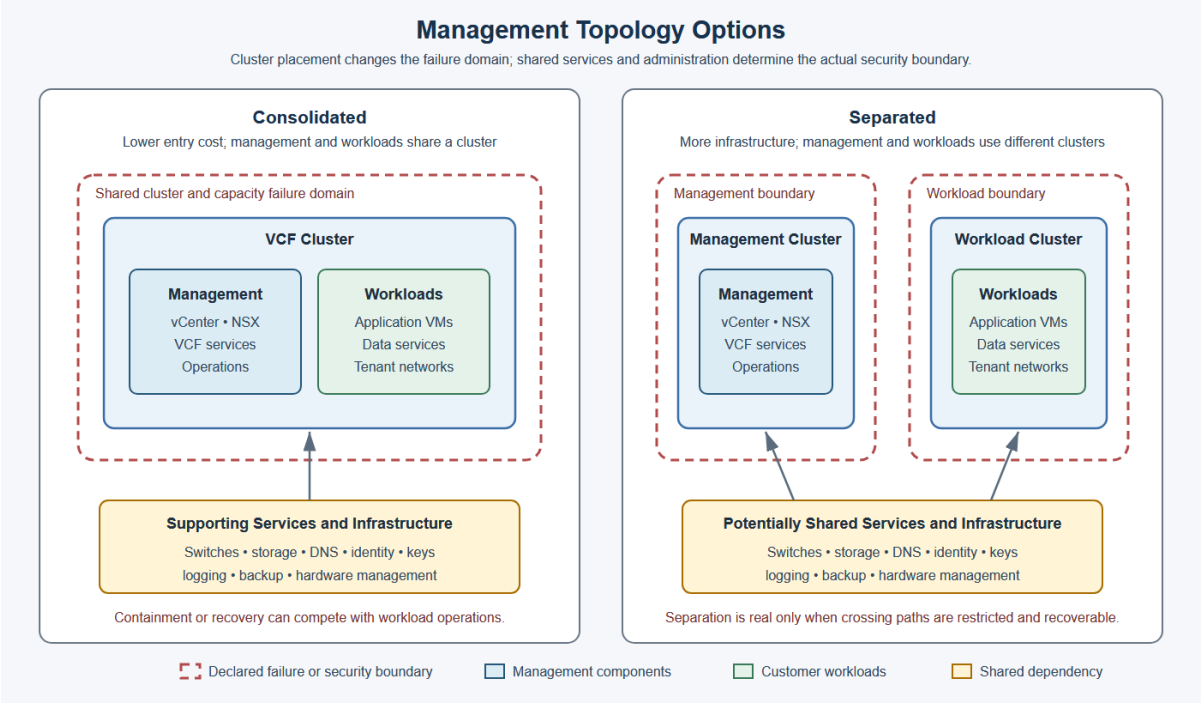


Figure 1. Management topology options. A separated cluster is not automatically a fully independent security boundary.

Compare the Choices

Decision Area	Consolidated Management and Workloads	Separated Management and Workloads
Security boundary	Management components and customer workloads share hosts and usually more supporting infrastructure. Logical segmentation carries more of the burden.	Dedicated management hosts permit separate host, network, and capacity policy. Shared upstream services can still join the failure domains.
Cost and minimum scale	Lower hardware and operational entry cost. Useful where a dedicated management cluster is disproportionate.	More hosts, ports, capacity, and lifecycle work. The cost can be spread across several workload domains.
Operational complexity	Fewer clusters and less duplicate infrastructure, but maintenance and capacity decisions can affect management and workloads together.	More systems to operate, but ownership, maintenance, and incident actions can be clearer.
Failure domain	Host, storage, or network failures can affect both management and customer workloads.	Cluster-level failures can be independent. Common DNS, identity, key, storage, or switching services may still fail together.
Containment	Quarantining a shared cluster or fabric can disrupt the tools needed to manage the incident.	Management paths can remain available while workload boundaries are tightened, if the control plane has independent reachability.

Decision Area	Consolidated Management and Workloads	Separated Management and Workloads
Recovery	Recovering management and workloads may compete for the same surviving resources.	A management domain can provide a base for workload recovery, but it still needs a tested recovery method of its own.
Best fit	Smaller sites, edge footprints, labs, and lower-consequence environments with strong logical controls.	Larger or higher-consequence environments, multiple workload domains, and designs requiring clearer separation of duties or failure domains.

VCF documentation has described both consolidated and separated models, with the separated model recommended where scale permits because it separates management from customer workloads.[13] Treat that as a starting point, not proof of physical isolation. Two clusters can still share top-of-rack switches, storage, a key provider, corporate identity, a backup administrator, or the same remote console network.

Make the Boundary Real

For a separated topology, list every path that crosses between the management and workload sides:

- vCenter and ESX management
- NSX Manager, edge-node, and overlay control traffic
- DNS, Network Time Protocol (NTP), identity, certificate, and key services
- VCF Operations, VCF Log Management, and VCF Management Services
- backup, snapshot, replication, and recovery orchestration
- hardware management controllers and administrative jump hosts
- software depots, proxies, update services, and outbound licensing paths
- monitoring, ticketing, paging, and out-of-band communications

Then decide who can use each path, from which administration zone, under what identity, and how the path is logged. A dedicated cluster may still use a shared domain-admin group and an unrestricted management VLAN. That design is separated on the rack diagram but not in the attack model.

Implementation and Validation

1. Draw the physical hosts, switches, storage systems, management controllers, and administrative entry points for both sides.
2. Add the logical VLAN, NSX overlay, routing, firewall, identity, key, logging, and backup paths.
3. Mark every component whose loss prevents management access or workload recovery.
4. Test management during a simulated workload-network quarantine.
5. Test workload recovery when corporate identity and the ordinary administrator workstation network are unavailable.
6. Record which shared paths are accepted and who approved each one.

Decision record: State whether the topology is consolidated or separated. Identify physical and logical boundaries, shared services, and the recovery use case that drove the choice.

Secure the Platform Foundation

The management plane has unusual reach. It can create, move, reconfigure, encrypt, snapshot, or delete workloads. It can also change the networks and services on which recovery depends. Protect it as a high-consequence service, not as another collection of virtual machines.

A sound foundation combines several kinds of control. Physical and firmware controls establish a known starting point. Network boundaries restrict who can reach management interfaces. Administrative identity controls restrict who can act. Independent DNS, time, logging, and key services keep those controls usable during an incident. None of these layers substitutes for the others.

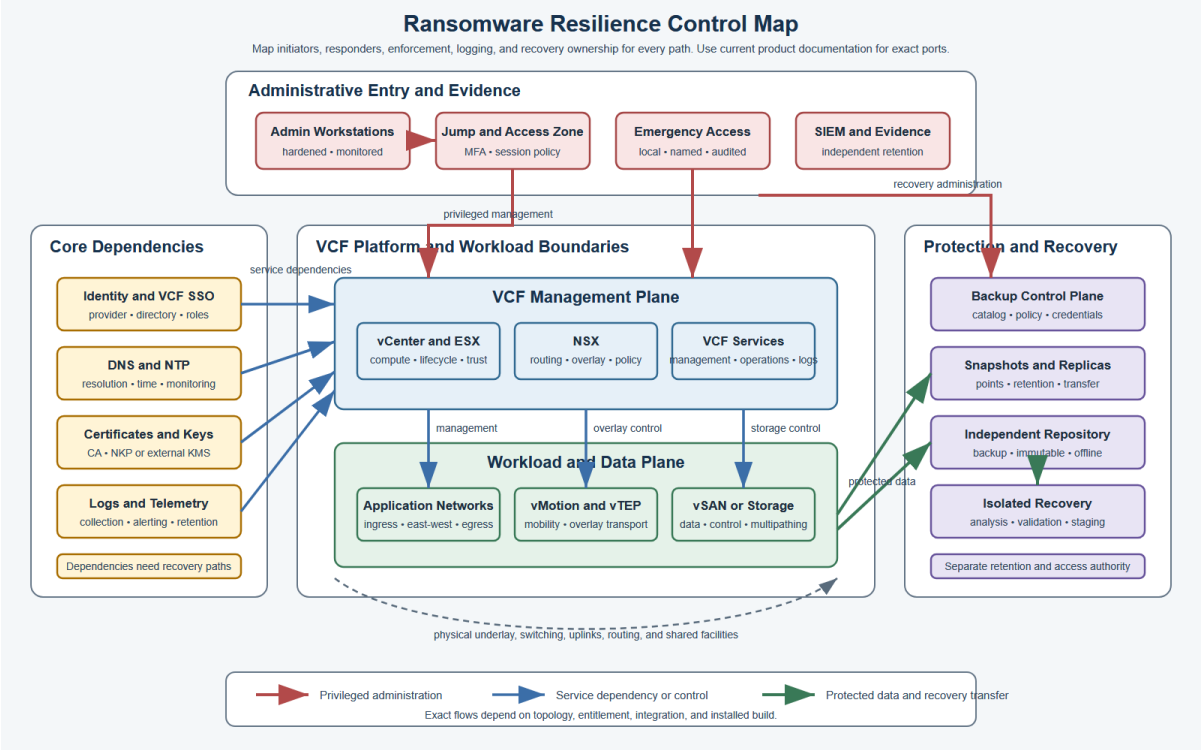


Figure 2. Ransomware resilience control map. Arrows represent classes of traffic, not a complete port or protocol specification.

Hardware and Physical Controls

Start with a simple assumption: repeated physical access to a server, switch, storage system, console, or management controller can bypass operating-system controls. A locked rack is not a complete security program, but software policy cannot compensate for uncontrolled physical access.

Physical controls should match the consequence of the equipment. A small remote site may rely on a locked room, recorded access, and tamper alerts. A central management or recovery site may warrant cages, separate access roles, surveillance, visitor procedures, and independent alert handling. Include spare parts, retired media, crash carts, and remote console networks in the same assessment.

Firmware resilience is platform-dependent. NIST SP 800-193 organizes it around protection, detection, and recovery.[14] When selecting servers and appliances, ask vendors to document the mechanisms they actually provide rather than assuming that similar feature names have identical behavior.

Decision Area	Questions to Resolve
Supply chain	How are firmware and components authenticated? Who receives and checks equipment? How are unexpected substitutions handled?
Configuration protection	Can firmware settings be locked or measured? Who controls the setting and its recovery secret?
Tamper detection	Does the platform report chassis opening, component changes, or security-setting changes? Where are those events sent?
Firmware recovery	Can the platform restore a known firmware image after corruption? Which credentials, media, and network services does recovery require?
Baseboard management controller	Is the controller on an independent network? Does it use centralized identity, local emergency access, or both? Are its logs exported?
Media handling	How are failed drives, boot devices, TPMs, and replaced system boards tracked, cleared, returned, or destroyed?

Recommendation: Send physical-access and management-controller events to a system that the local platform administrator cannot silently rewrite. Test the alert path. An enabled chassis sensor has little value if no one sees its event.

Establish Host Trust Without Overstating It

Secure Boot, signed components, a Trusted Platform Module (TPM), and host attestation help establish an ESX host's starting state. vCenter can report host-attestation status when the supported TPM and firmware conditions are present.[15] These mechanisms do not scan virtual-machine data, detect ordinary guest malware, or decide whether an administrator's action is legitimate.

TPM-backed protection also creates a recovery obligation. A system-board, TPM, or firmware change can require the ESX configuration recovery key. Store that key away from the host and away from the administrator path that could be compromised with it.[16] Record the retrieval procedure, required approvals, and a reinstall path if the key cannot be recovered.

Do not enable a firmware trust feature solely because the processor exposes it. Confirm the server model, firmware, TPM, Secure Boot, attestation, device, and VCF compatibility requirements. Intel Trusted Execution Technology (TXT) is one platform-specific choice, not a universal instruction. Use the supported equivalent for the selected platform where one exists.

Lockdown Mode is another choice with a recovery tradeoff. Normal and strict modes restrict direct ESX administration differently. Strict Lockdown Mode can leave an operator without direct host access when vCenter is unavailable unless the exception and recovery path were prepared in advance.[17]

Host-Control Choice	Security Contribution	Recovery or Operations Cost	Validation Question
Secure Boot and signed components	Restricts the trusted boot chain to accepted components	Unsigned or incompatible extensions cannot load	Does every required driver and extension pass the installed-build check?
TPM-backed configuration protection	Binds protected host configuration to platform state	Hardware or firmware changes can require a recovery key	Can an authorized operator retrieve the right key when vCenter is unavailable?
Host attestation	Reports measured platform state to vCenter	Depends on supported firmware, TPM, and management availability	Which alert and response follow an attestation failure?

Host-Control Choice	Security Contribution	Recovery or Operations Cost	Validation Question
Normal Lockdown Mode	Restricts most direct host administration while retaining defined exception paths	Exception accounts increase the access surface	Are exceptions limited, monitored, and usable during a vCenter outage?
Strict Lockdown Mode	Further restricts direct host administration	Loss of vCenter can make the host difficult to manage	Has the team rehearsed the supported recovery procedure?

ESX 9.1 uses User-Level Monitor as the default virtual-machine monitor. Broadcom describes a lower-privilege user-mode process whose address space excludes host secrets and other virtual machines' memory.[18] This boundary reduces the potential reach of a monitor flaw. It does not inspect the guest or decide whether a workload action is malicious.

VCF 9.1 also enables File Integrity Monitoring for static vCenter files and binaries by default. The check runs every four hours, and operators can retrieve reports through the API or stream its logs through syslog.[18] Treat this as a change signal. It does not prove why a file changed or replace external log retention.

Patching remains one of the most direct ways to remove a known path. ESX Live Patch can apply eligible patches without evacuating virtual machines or rebooting a host, and ESX 9.1 extends that workflow to TPM-enabled hosts.[19] Only eligible patches receive that treatment. Prechecks, resource constraints, Device Processing Unit (DPU) use, and other workflow limits still matter. Reduced Downtime Upgrade can shorten parts of a vCenter upgrade, but planned downtime can still occur.[20]

Implementation and validation

1. Record the approved server, firmware, device, TPM, Secure Boot, and attestation state in the build standard.
2. Export ESX configuration recovery keys to an access-controlled repository that does not depend on the affected host.
3. Send host-attestation, firmware, hardware-management, and physical-tamper events to the monitoring path.
4. Test a supported board or TPM recovery scenario in nonproduction equipment.
5. Test vCenter loss under the selected Lockdown Mode. Confirm that the response team can gain approved emergency access and that the action is logged.
6. For each patch cycle, distinguish live-patch-eligible updates from updates that require evacuation, reboot, or a maintenance window.

Separate Networks by Function and Consequence

Network separation is useful when it restricts a real path. Several VLANs may still allow one administrator, jump host, or broad firewall rule to reach everything. That changes the diagram more than the risk.

VCF designs commonly carry management, vMotion, vSAN or external storage, NSX overlay endpoint, workload, backup, and recovery traffic. Some designs share physical adapters or switches while separating traffic logically. Others dedicate adapters, switches, or fabrics. Decide based on the consequence of congestion, interception, misconfiguration, and containment, not on the number of labels in a reference diagram.

Traffic or Control Path	Why It Matters During an Intrusion	Typical Boundary Question
ESX and vCenter management	Carries high-privilege control operations	Can only approved administration zones and named services initiate sessions?
vMotion	Moves running workload state between hosts	Is it restricted to the required hosts and protected from ordinary workload networks?

Traffic or Control Path	Why It Matters During an Intrusion	Typical Boundary Question
vSAN or external storage	Carries workload data and storage control traffic	Can a compromised workload, edge, or administrator endpoint reach the storage plane?
NSX overlay endpoint	Carries encapsulated workload traffic between transport nodes	Are transport-node reachability and the underlay failure domain understood?
NSX and vDefend management and control	Changes NSX routing and switching or vDefend security policy	Are administration, API clients, backups, and emergency access separately controlled?
Identity, DNS, NTP, certificates, and keys	Determines whether systems can authenticate, resolve, validate, decrypt, and correlate events	Which independent instance remains available after site or enterprise-identity loss?
Logs and telemetry	Supplies evidence for detection and investigation	Can the observed administrator alter both the source and the retained copy?
Backup and recovery	Reads broad data sets and can restore or delete copies	Does it use a distinct identity, route, and retention authority?
Hardware management	Can power-cycle, mount media, or reconfigure a server	Is it isolated from ordinary host and user administration?

Use Broadcom's Ports and Protocols tool for the current source, destination, protocol, port, and purpose information.[21] A static list in a design guide ages quickly. Generate rules from the installed builds and integrations, then test that required flows work and unapproved flows do not.

Segmentation can exist at several layers:

- The underlay carries physical and routed connectivity among hosts, switches, gateways, and external services.
- The NSX overlay supplies logical workload networks and routing over that underlay.
- VMware vDefend Distributed Firewall, when separately licensed and deployed, enforces policy close to workload interfaces.
- VMware vDefend Gateway Firewall, when separately licensed and deployed, enforces supported gateway paths.
- Physical or virtual firewalls can control administration, storage, backup, recovery, and north-south boundaries that do not pass through distributed enforcement.
- Avi Load Balancer can publish applications and, with the applicable edition, apply Web Application Firewall (WAF) policy to HTTP/S traffic.[22][23]

A WAF can filter application-layer requests. It does not inspect every management, storage, remote-access, or workload protocol. Likewise, a distributed firewall rule does not protect traffic that never crosses its enforcement point. Draw enforcement on the traffic map and identify every bypass.

Choose Link Resilience Deliberately

Link redundancy and security meet during containment. An operator needs to know whether a failed link, failed switch, mistaken quarantine, or partial network path will be detected without creating a second outage.

Method	Appropriate Use	Important Limits
Originating virtual port or explicit failover	Simple uplink redundancy with independent switch paths	Detection depends on the selected failure criteria and upstream design. A physically up link may still have a broken path.

Method	Appropriate Use	Important Limits
Link Aggregation Control Protocol (LACP)	A supported vSphere Distributed Switch design with matching physical-switch configuration	Validate NSX, storage, blade, SR-IOV, hashing, and vendor topology support. LACP is not available on a standard switch.[24]
Beacon probing	Detecting certain upstream failures when at least three uplinks use separate physical-switch paths	It is designed for three or more uplinks and does not detect every partial path failure. It is not a blanket recommendation for vSAN.[25]
Storage multipathing	Redundancy for supported external block-storage paths	Configure and monitor it with the storage vendor's supported policy. Network-interface teaming does not replace storage multipathing.

Decision record: For every traffic class, record the logical boundary, physical path, enforcement point, permitted initiators, required responders, failure-detection method, log destination, and recovery owner.

Design Administrative Identity for Survivable Access

Centralized sign-on makes routine administration easier to govern. It can also make the same identity outage or compromise affect every management component. The design goal is not to abandon federation. It is to separate authentication, authorization, emergency access, and recovery responsibilities so that one account or service cannot silently control all four.

VMware Identity Broker brokers VCF SSO between VCF components and a configured external identity provider or directory. In VCF 9.1 it is deployed with VCF and can run embedded or as an appliance cluster.[18] The external provider determines available MFA and conditional-access methods. Confirm support for the provider and method in the installed release.

Identity Pattern	Advantages	Costs and Failure Conditions	Good Fit
Corporate identity tenant with dedicated VCF groups	Familiar lifecycle, existing MFA, and centralized user governance	Corporate compromise or outage can affect platform access. Corporate identity administrators may gain indirect control of VCF roles.	Organizations with mature identity governance and a tested emergency path
Dedicated infrastructure tenant or directory	Separates infrastructure accounts and authorization ownership from ordinary enterprise administration	Adds another critical service, recovery process, monitoring path, and set of privileged operators	Higher-consequence environments that can operate the extra control plane
Federation to a dedicated infrastructure directory	Separates local infrastructure identities while using an external provider for policy and MFA	Federation, certificates, name resolution, and both identity systems become dependencies	Organizations needing distinct infrastructure ownership with centralized access policy
Local component accounts	Can provide component access when federation is unavailable	Difficult to govern at scale; password drift and shared use reduce accountability	Emergency access and narrowly scoped service recovery, not routine administration

Authentication answers who presented a credential. Authorization answers what that identity may do. Keep the authorization map in the infrastructure owner's control. If a corporate group receives an infrastructure role, record who can change the group, who approves membership, and how quickly membership changes are detected.

Phishing-resistant MFA is preferred for privileged access where the chosen provider and client path support it. MFA does not repair excessive authorization. A help-desk process that can reset a privileged factor without independent verification may become the easier path. Require stronger identity proofing and separate approval for privileged-factor resets, recovery-code issuance, and new authenticator enrollment.

Emergency access must survive the failure it is intended to address. Keep a small number of named, local, nonfederated accounts where the product requires or supports them. Protect credentials in a controlled system that is reachable during identity and network outages. Monitor every use. Rotate the credential after use or exposure, and test the complete retrieval and sign-in procedure.

Implementation and validation

1. Map each privileged role to named job functions, approvers, identity groups, and emergency substitutes.
2. Remove routine platform administration from ordinary user workstations. Use hardened administrative workstations or jump hosts on controlled paths.
3. Separate interactive administrators, service accounts, API clients, backup identities, and break-glass accounts.
4. Alert on successful unusual sign-ins, role and group changes, MFA changes, new API clients, emergency-account use, and policy changes.
5. Simulate loss of the external identity provider. Confirm access to vCenter, NSX, VCF Operations, VCF Management Services, VCF Log Management, key services, backup systems, and hardware consoles.
6. Simulate compromise of an identity administrator. Confirm that infrastructure role changes require a separate owner or generate an actionable alert.

Keep Core Dependencies Available and Trustworthy

Management systems depend on services that are easy to omit from a recovery diagram. DNS locates components. Time supports authentication, certificate validation, distributed-system behavior, and event correlation. Key providers unlock encrypted systems. Logging preserves evidence. If those services disappear with the production environment, a recovery plan may stop before the first workload starts.

Do not place every dependency on one unclustered ESX host merely to call it independent. That host becomes a concentrated failure domain with a unique patch, access, monitoring, and recovery path. Redundant services in a protected management domain, a separate infrastructure-services cluster, or recovery-site instances may be better. The right choice depends on scale and failure assumptions.

Dependency	Primary Environment	Recovery Site	Isolated Recovery Environment	Validation Focus
DNS	Authoritative or forwarding service for VCF and workloads	Recoverable zones and resolvers that do not require the failed primary site	Restricted resolution for recovery tools, candidate systems, and approved update or analysis services	Resolve forward and reverse records with the primary DNS path unavailable
NTP	Monitored site-local sources with diverse upstreams	Independent or survivable sources	Controlled sources available without production access	Detect skew, loss, and a false source; correlate events across zones
Identity	Routine federated access plus controlled local emergency access	Required directory, provider, or recovery workflow	Recovery-team identities that do not trust candidate systems	Sign in, authorize, revoke, and audit when corporate identity is unavailable
Certificates	Issuance, trust, renewal, and revocation paths	Protected CA state or documented reissuance method	Required trust anchors and validation services	Recover expired, revoked, or unavailable certificate services

Dependency	Primary Environment	Recovery Site	Isolated Recovery Environment	Validation Focus
Key provider	Clustered provider and protected recovery material	Keys and trust procedure for protected workloads	Only the keys needed for selected recovery points	Power on encrypted and vTPM-enabled test workloads after provider loss
Logging	Central collection outside ordinary workload administration	Retained platform, identity, network, and backup evidence	Collection for candidate-system and recovery-operator activity	Search evidence after source systems and normal SSO are unavailable
Backup catalog and orchestration	Protected control plane with separate administration	Recoverable catalog, configuration, and credentials	Approved access to selected copies and recovery networks	Restore when the primary control plane or its administrator is compromised

DNS

Treat namespace data and the DNS administration plane as recovery assets. Protect zones, records, signing keys, delegations, resolver configuration, and the credentials that can change them. A cloud-hosted DNS service can reduce dependence on a local site, but it still depends on provider access, account recovery, API credentials, and correct delegation.

DNS Security Extensions (DNSSEC) provide data-origin authentication and integrity for signed DNS data. They do not provide confidentiality or denial-of-service protection, and they are not a general ransomware control.[26] Choose time-to-live values based on measured availability and change needs. Short caching can make legitimate changes visible sooner, but it increases query dependence. Long caching can carry known answers through an outage, but it can delay corrections.

Time

Use monitored, independent time sources. RFC 8633 recommends at least four independent and diverse Network Time Protocol sources for operators concerned with accurate time.[27] Four names that point to the same provider, circuit, or upstream clock are not diverse. Site-local relays can reduce external dependence, but the relays need their own resilient upstreams and alerting.

Logging

VCF Management Services is a required runtime in VCF 9.1. It hosts lifecycle and operational services and incorporates the VMware Identity Broker architecture.[28] Treat it as part of the management-plane dependency map. Its access, certificates, networking, logs, and recovery path should not depend on one untested VCF SSO session or administrator workstation.

VCF Log Management 9.1 is integrated into VCF Management Services, with lifecycle and security workflows exposed through VCF Operations. Broadcom also documents a separate break-glass access path.[29] Integration changes where the team must test VCF SSO, lifecycle, and emergency access. It does not remove the need to protect retained logs from the administrators and systems being observed.

Define retention from the investigation need, not only daily log volume. Preserve identity, API, vCenter, ESX, NSX, firewall, load balancer, DNS, NTP, key-provider, backup, hardware-controller, endpoint, and recovery activity. Normalize time and identity fields so investigators can follow one action across systems.

Encryption Keys

Encryption helps protect data against storage theft and unauthorized reads. It can also block recovery until the key service, trust relationship, certificate, backup, or credential is restored. A locked encrypted virtual machine or disk may not power on until the required key is available.[30]

Choice	External Dependency	Recovery Material	Operational Considerations	Design Limit
vSphere Native Key Provider	No external Key Management Interoperability Protocol server	Password-protected PKCS#12 backup stored outside the cluster; optional TPM restriction	Clustered hosts are required. Back up the provider before use. Protect both the file and its password.[31]	Availability follows the supported cluster and vCenter design. It is not an external separation boundary.
Standard Key Provider	External Key Management Server (KMS), network path, certificates, and established trust	KMS backups, keys, certificates, configuration, credentials, and trust-recovery procedure	Can provide a distinct operational and compliance boundary. Avoid hosting every KMS dependency inside the environment it unlocks.[32]	Loss of the KMS or trust can lock protected workloads even when their storage is intact.

A virtual TPM (vTPM) is virtual. Its protected state depends on virtual-machine encryption and on the key-provider design. A restored vTPM-enabled guest may fail to start or use protected guest features when its key is unavailable.[33] Do not describe vTPM data as though every secret remains inside a physical chip.

Decision record: Name the authoritative owner for DNS, NTP, identity, certificates, keys, logging, and backup control. Record ordinary and emergency access, primary and recovery instances, protected configuration, restore order, and the last successful outage test.

Design Workloads for Containment and Recovery

The infrastructure team can recover a virtual machine without recovering the business service. An application may still need a database, directory, DNS record, certificate, key, load balancer, message queue, file share, external API, or license server. Design and test the service as a dependency group.

Classify Workloads Before Selecting Tools

Start with business impact and dependency behavior. Tool selection comes later. Two measures are useful when they are defined precisely:

- **Recovery time objective (RTO)** is the maximum time a system resource may remain unavailable before the impact becomes unacceptable.
- **Recovery point objective (RPO)** identifies the point in time to which data must be recoverable and therefore the tolerated data loss.[34]

A four-hour backup interval does not prove a four-hour RPO. Failed jobs, delayed copies, retention, consistency, and the age of the selected clean point all matter. Replication can reduce potential data loss, but orchestration, dependency recovery, validation, and startup determine the achieved recovery time.

Classify each service with enough information to choose a recovery pattern:

Attribute	Questions to Answer
Business consequence	What stops if the service is unavailable, corrupt, or publicly exposed? When does the impact become unacceptable?
Data tolerance	How much committed data can be reconstructed or lost? Does the answer differ for disaster and cyber recovery?
Dependency group	Which systems must start first, and which must remain isolated until later?
Consistency	Does recovery require application-aware processing, coordinated multi-VM state, or a database-native method?
History depth	How far back might the team need to go if attacker activity preceded detection?
Validation	Which technical and business checks establish that the service is usable and sufficiently trusted?
Exposure	Which inbound, outbound, administrative, and partner paths are required during recovery?
Owner	Who approves the recovery point, data reconciliation, and return to service?

Do not assign the same RTO and RPO to every component because they share an application name. An identity service may need to start before the application. A reporting node may wait. A payment or clinical-data store may require a stricter consistency and validation process than a stateless web tier.

Map the Application Dependency Group

Draw the service from the user's request inward. Include ingress, name resolution, load balancing, application tiers, data, identity, keys, certificates, time, monitoring, and outbound integrations. Record direction, protocol, owner, recovery source, startup order, and what happens when the dependency is unavailable.

Remote dependencies add protocol round trips and may accumulate latency. Do not infer application response time from network round-trip time alone. Measure the actual transaction, including DNS, TCP, Transport Layer Security (TLS), authentication, database, and application exchanges.

For Microsoft Active Directory, use Microsoft's forest-recovery procedure for the deployed Windows Server versions. Restore at least one domain controller in each domain from a trusted backup. Begin with a writable domain controller in the forest-

root domain.[35] That is a directory recovery workflow, not a universal instruction to restore every existing controller or create a special standalone controller.

At the recovery site and in an isolated recovery environment, decide whether each dependency will be:

- already running and independently administered;
- started from a protected recovery copy;
- reconstructed from configuration as code or a known image;
- temporarily substituted by a controlled service; or
- deliberately unavailable while candidate systems are examined.

Example: A recovered application may start with a local service account while its external identity provider is unavailable. That result does not prove the normal user path works. Test both the emergency mode and the transition back to the intended identity path.

Segment Workloads Around Application Intent

Microsegmentation works best when policy describes the application's allowed relationships. A rule such as "web tier can reach application tier on these services" is easier to investigate than a broad rule for an entire subnet. Start with observed and documented flows, then have the application owner approve the allowlist and exceptions.

Separate these policy questions:

- **East-west:** Which workload-to-workload flows are required inside and between applications?
- **North-south ingress:** Which users, partners, and services may initiate connections, and where are TLS and WAF controls applied?
- **Egress:** Which update services, APIs, mail relays, repositories, and destinations may a workload reach?
- **Administration:** Which tools and identities may manage the guest, application, database, or middleware?
- **Recovery:** Which additional paths are allowed while a service is restored, examined, or reconciled?

Security groups and tags can make policy follow a workload, but automatic membership deserves the same change control as the rule. Protect the systems and identities that assign tags. Alert on changes that place a workload into a more privileged group.

Preserving network identity across sites may simplify disaster recovery. It can also carry an existing security context and compromised relationships into the recovery site. Decide whether cyber recovery should reuse that network identity or place candidate systems on newly controlled networks.

Application ingress has its own boundary. Avi Load Balancer can provide load balancing and optional WAF policy for HTTP/S applications. A WAF may filter exploit attempts against a web application. It does not control administrative protocols, outbound command traffic, database access, or malware already present on a guest.

Remote access should land in an administration or application access zone, not directly on ESX, vCenter, NSX Manager, storage, backup, or hardware-management interfaces. Apply strong authentication, device policy, session logging, and time-bounded authorization. Separate vendor support access from ordinary employee access and disable it when the approved work ends.

Make the Workload Easier to Rebuild

A repeatable build reduces the number of decisions made under incident pressure. Protect source images, templates, automation, package repositories, configuration, secrets, certificates, and the identities that publish them. A compromised template can reproduce the intrusion faster than a manual build.

Keep operating-system and application binaries separate from business data where the application supports it. The separation can let a team rebuild a known operating environment and attach or restore validated data without preserving unnecessary system state. It is an application design choice, not a guarantee that the data volume is clean.

Use guest Secure Boot, vTPM, disk encryption, and application controls for their documented purposes. Secure Boot validates the trusted boot path; it does not detect arbitrary malware in a running guest. A vTPM-backed guest feature depends on the virtualization key path during restore. Include those dependencies in the recovery test.

Create a service-startup and shutdown plan. State which databases, directories, brokers, queues, and application tiers must be consistent. Identify components that cannot tolerate simultaneous startup or replay. Where the protection method lacks multi-VM consistency, use an application-aware method or the vendor's supported recovery workflow.

Implementation and validation

1. Assign business owners to approve the disaster-recovery and cyber-recovery RTO, RPO, and validation criteria for each service.
2. Export observed flows, compare them with application documentation, and obtain application-owner approval before enforcing an allowlist.
3. Recover the dependency group into a controlled network with production routes closed.
4. Confirm name resolution, time, identity, certificates, keys, application consistency, data reconciliation, and monitoring in startup order.
5. Test loss of one external dependency at a time. Record whether the application fails closed, degrades, queues work, or corrupts state.
6. Rebuild at least one representative workload from protected images and configuration rather than restoring the complete virtual machine.

Decision record: For every important service, record its owners, business impact, RTO, RPO, dependency graph, consistency method, and history depth. Add permitted recovery flows, required validation evidence, and return-to-service authority.

Detect, Investigate, and Contain

Detection is not one product or one alert. An attacker may use a valid account, a built-in administrative tool, and an allowed network path. The useful signal is often a change in behavior across identity, endpoint, network, platform, and backup systems.

Collect enough context to answer four questions quickly:

1. Which identity or workload acted?
2. What changed, and where else did that identity or system act?
3. Which recovery assets and control planes were reachable?
4. Which containment action reduces harm without destroying evidence or disabling recovery?

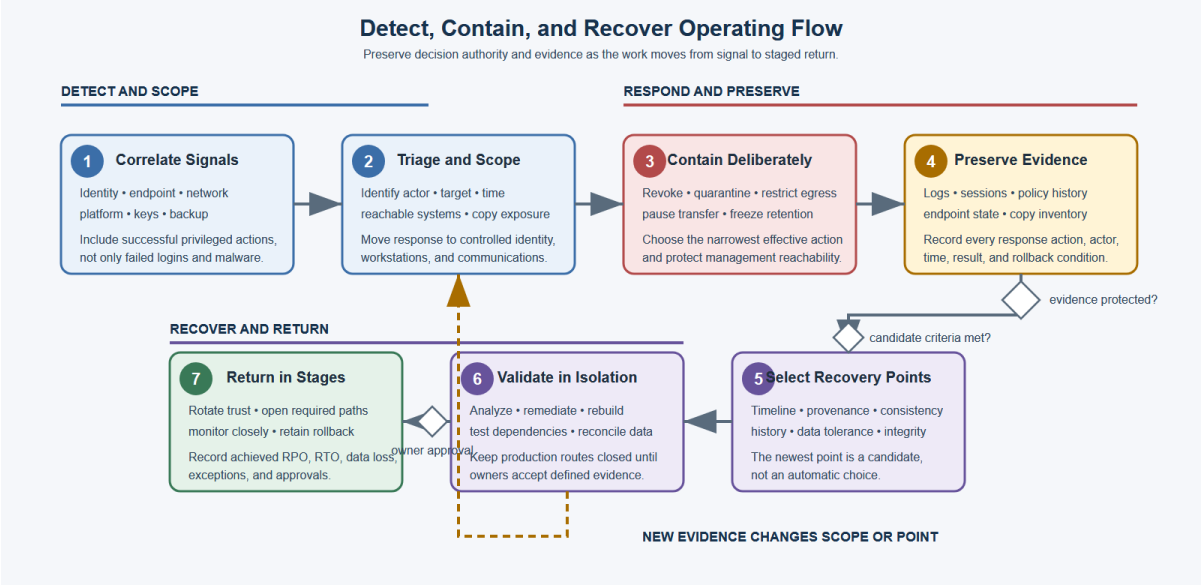


Figure 3. Detect, contain, and recover operating flow. The response can loop back when new evidence changes the incident scope or selected recovery point.

Combine Signals Across Control Planes

The most important events are not always failures. Consider a successful privileged login from a new device or an approved tool used at an unusual hour. A valid API token deleting protection policies may deserve more attention than repeated failed logins.

Signal Source	Examples Worth Correlating	Context Needed
Identity provider and VCF SSO	New MFA method, factor reset, unusual successful sign-in, group change, role assignment, new application or API client	Requestor, approver, source device, location, session, previous behavior, resulting VCF role
vCenter and ESX	New administrator, host-service change, Lockdown Mode change, datastore action, bulk VM power or reconfiguration event, attestation change	Actor, API client, target set, maintenance record, preceding identity activity
NSX and vDefend	Security-policy change, unexpected group membership, new route, blocked or unusual lateral flow, IDS/IPS or network-analysis alert	Rule before and after, tag source, flow direction, owning application, endpoint alert

Signal Source	Examples Worth Correlating	Context Needed
Avi Load Balancer	WAF event, virtual-service change, certificate change, unusual request or response pattern	Application owner, source, URI or service, policy, related workload and identity activity
Endpoint and workload tools	Malware behavior, credential access, process injection, service creation, disabled agent, mass file changes	Process tree, user, hash, network connection, affected data, containment status
DNS, proxy, and egress controls	Newly observed domains, algorithmic queries, unexpected direct IP traffic, large transfer, bypass of proxy policy	Workload role, destination history, bytes, process, approved integration
Key provider and certificates	Failed key retrieval, trust re-establishment, certificate replacement, administrative login, key or policy change	Requesting system, administrator, change record, affected encrypted objects
Backup and recovery	Retention reduction, job disablement, protection-group change, catalog login, copy deletion, unusual restore, failed immutability check	Actor, source path, affected history, independent copy status, approved ticket
Hardware and physical systems	Remote-console session, virtual-media mount, power cycle, firmware change, chassis event	Badge or operator identity, source network, change record, affected host

VCF Log Management centralizes supported log workflows in VCF 9.1 through VCF Management Services and VCF Operations.[29] Include those services in identity, availability, backup, and emergency-access plans. Centralization helps correlation, but a single retained copy under the same administrator does not provide independent evidence.

VMware vDefend can add Distributed Firewall, Gateway Firewall, and edition-dependent threat-prevention signals.[22] It is separately licensed. Endpoint detection and response remains important inside supported guests because network telemetry cannot show every process, file, or credential event.

ESX 9.1 also supports compatible partner endpoint detection and response (EDR) agents on the hypervisor. The agent runs in an isolated host container and can report process and network-connection events to the vendor's management platform.[18] This option depends on the EDR vendor providing a compatible agent. It is separate from guest EDR and from vDefend network controls.

Feed high-consequence alerts and configuration changes to the security information and event management system (SIEM) or the organization's equivalent investigation platform.

Design the Investigation Path Before the Incident

An investigation workspace should not depend on the suspected administrator workstation or production identity path. Provide the response team with controlled workstations, a communication channel, evidence storage, and access to retained logs. Document how those tools work if the corporate directory, email, ticketing system, or normal network is unavailable.

Normalize identity. The same person may appear as an email address, security identifier, VCF principal, local account, API token owner, and hardware-controller user. Keep the mapping and group history long enough to reconstruct past access. Current membership does not show who held a role when an event occurred.

Preserve volatile and durable evidence in an order agreed with incident-response and legal owners. Evidence needs vary by event and jurisdiction. Do not casually delete snapshots, logs, memory state, endpoint records, affected accounts, or malicious artifacts. The response owner should decide what must be retained. CISA recommends preserving evidence and coordinating isolation because unplanned disconnection can interfere with investigation or response.[8]

Give Containment Actions Owners and Limits

Fast containment is useful only when someone has authority to use it and understands the consequence. A firewall block that isolates a compromised application may be safe. Disconnecting the management network can also cut off logging, key access, backup jobs, and the tools needed to recover.

Containment Action	Likely Benefit	Possible Cost	Required Owner or Precondition
Disable or revoke an identity session	Stops continued use of a known account or token	Can interrupt automation or remove the only working administrative path	Identity and service owner; tested emergency substitute
Remove a workload from ordinary networks	Restricts lateral and command traffic	May stop evidence collection, time, identity, or application consistency	Incident commander and application owner; quarantine network available
Apply a distributed firewall quarantine	Restricts selected virtual interfaces while preserving host access	Incorrect dynamic-group logic can capture healthy systems	Network security owner; static emergency rule and rollback plan
Block north-south or egress paths	Restricts data transfer and external command traffic	Can interrupt customer service, updates, cloud dependencies, or response tooling	Network and business owner; approved exceptions
Suspend replication	Reduces the chance of copying further attacker changes	Increases data-loss exposure if the incident is a false positive or a separate outage occurs	Recovery owner; retained point-in-time history and decision trigger
Freeze retention and backup-policy changes	Preserves available recovery history	May increase capacity consumption or cause jobs to fail if storage fills	Backup owner; capacity monitoring and escalation path
Isolate an ESX host	Restricts host communication	Can strand workloads or remove management and forensic visibility	Platform and incident owners; workload placement and console access known
Disable a management API client	Stops an automation or token path	Can halt lifecycle, monitoring, or recovery automation	Component owner; client inventory and manual alternative

Prepare narrow actions before broad ones. For example, create a quarantine group that permits only approved investigation, logging, DNS, and time paths. Test membership changes and rollback. Do not wait for an incident to discover that a dynamic tag also includes the recovery appliance.

Use a Decision-Based Response Runbook

A ransomware runbook should contain decision points, not only a fixed sequence. New evidence can widen or narrow the incident and change which recovery point is acceptable.

1. **Declare ownership.** Name the incident commander, technical leads, evidence owner, communications owner, and business decision maker.
2. **Protect the response path.** Move coordination and administration to controlled systems and identities.
3. **Preserve available history.** Restrict retention changes and copy deletion. Capture relevant identity, endpoint, network, platform, key, and backup evidence.
4. **Scope access.** Identify affected accounts, API clients, workloads, management components, and reachable recovery systems.
5. **Contain deliberately.** Choose the narrowest action that reduces continuing harm. Record the action, actor, time, expected effect, and rollback condition.
6. **Select candidate recovery points.** Use the intrusion timeline, data needs, copy integrity, and history depth. Do not assume that the newest copy is the best one.
7. **Validate in a controlled environment.** Examine systems without granting ordinary production access.

8. **Approve return to service.** Require security, application, data, infrastructure, and business acceptance for their respective criteria.
9. **Monitor the transition.** Watch restored identities, network flows, processes, data changes, and control-plane actions more closely during reintroduction.

Implementation and validation

- Generate an alert from each high-consequence source and verify collection, identity mapping, paging, and ownership.
- Run a tabletop in which the suspected actor is a vCenter administrator rather than an ordinary workload account.
- Quarantine a test workload while preserving the investigation, logging, DNS, and time paths.
- Revoke an external identity session and recover access with the approved emergency path.
- Suspend and resume a test replication or backup policy under two-person approval.
- Retrieve historical group membership, firewall policy, protection policy, and API-client ownership as they existed at a chosen time.
- Verify that the response team can communicate and reach evidence when corporate email and ordinary administrator workstations are unavailable.

Decision record: State who may declare an incident and who may revoke access, quarantine workloads, isolate hosts, suspend replication, or freeze retention. Assign separate authority for evidence, recovery-point approval, and return to service where appropriate.

Recover and Validate

Recovery is a choice of state, place, and trust. The newest copy may contain the attacker's persistence or destructive changes. The oldest clean copy may create unacceptable data loss. A fast failover may carry the compromise into a second site. A slower rebuild may produce greater confidence but miss the business recovery target.

Design enough history and enough separation to make that choice deliberately. Then define the evidence needed to return a service to production.

Distinguish Four Different Outcomes

High availability, disaster recovery, backup recovery, and cyber recovery solve related but different problems.

Outcome	Primary Problem	Typical Mechanism	Main Ransomware Limitation
High availability	A component, host, or local service fails	Restart, clustering, redundancy, or local failover	Healthy redundancy can preserve and restart a compromised state.
Disaster recovery	A site or infrastructure domain is unavailable	Replication, recovery plans, network mapping, and site failover	Recent replicas may contain the same corruption, credentials, or attacker access.
Backup recovery	Data or systems must return to an earlier point	Restore from retained point-in-time copies	Restore speed, consistency, dependency order, and copy age may not meet the service target.
Cyber recovery	Production trust is uncertain after an intrusion	Protected history, restricted administration, isolated examination, rebuild or restore, and staged return	Analysis reduces uncertainty but cannot prove that every hidden compromise is absent.

These outcomes can share technology. A replicated recovery point may support ordinary disaster recovery and, when protected as history and examined in isolation, contribute to cyber recovery. The design, retention, identity boundary, and operating process determine the result.

Name the Isolation You Actually Have

The phrase *air gap* is often applied too broadly. Use more precise terms:

- **Physical isolation** removes a physical communication path. A disconnected network or removable medium can provide it while disconnected.
- **Logical isolation** uses configured enforcement, such as routing, firewall policy, credentials, or restricted service endpoints, on connected infrastructure.
- **Offline copy** means the copy is not network-accessible during normal operation. Document how and when it becomes accessible.
- **Immutable copy** resists modification or deletion for a defined retention period and administrative scope.
- **Isolated recovery environment (IRE)** is a controlled network and tool set used to examine and recover candidate systems before production access is restored.

Each term describes a mechanism, not a cleanliness result. An offline tape, immutable snapshot, or isolated replica can preserve malware or attacker-created accounts that existed when the copy was made. Recovery confidence comes from protected history, known provenance, integrity checks, analysis, application validation, and controlled reintroduction.[8][36]

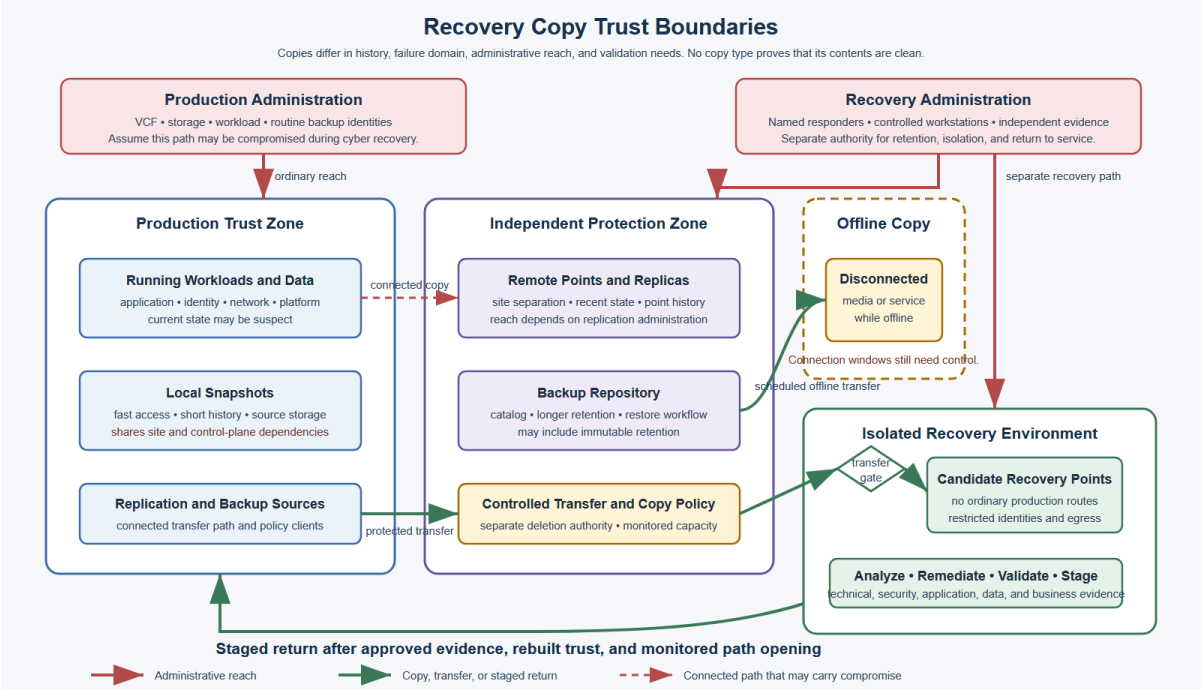


Figure 4. Recovery-copy trust boundaries. Conceptual design relationships; not a supported product topology.

Choose More Than One Kind of Recovery Copy

Copies have different strengths. A local snapshot can reverse an operator error quickly. A replica can reduce data-loss exposure after a site failure. A retained backup can reach farther into history. An offline or isolated copy can reduce an attacker's ordinary reach. No single property covers every failure.

Copy Type	Typical Purpose	Failure Domain	Ordinary Attack Reachability	Retention and History	RPO Contribution	RTO Contribution	Required Validation
Local snapshot	Fast rollback and short-term operational recovery	Usually shares source storage and site	Often reachable through the source control plane	Usually short; depends on capacity and policy	Frequent points may reduce potential data loss	Fast access can shorten restore time	Storage health, policy, crash or application consistency, dependency state
Remote snapshot	Additional site or storage-domain copy	Separate target when designed that way	Depends on replication and target administration	Product and policy dependent	Scheduled or continuous transfer can reduce data loss	Target proximity can speed restore	Target independence, point history, consistency, target credentials
Replica	Site recovery and planned migration	Separate compute or storage target	Replication path and orchestrator usually remain connected	Often favors recent state unless point history is retained	Can support a low RPO	Recovery plans can reduce orchestration time	Recovery-plan mapping, dependency startup, selected point, network containment

Copy Type	Typical Purpose	Failure Domain	Ordinary Attack Reachability	Retention and History	RPO Contribution	RTO Contribution	Required Validation
Backup	Point-in-time restore and longer retention	Repository design dependent	Control plane or repository may be reachable from production	Can retain broader history	Schedule and job success bound available points	Restore, transfer, indexing, and rebuild time can be substantial	Catalog recovery, media integrity, application consistency, full restore test
Offline copy	Separation from ordinary network access	Separate while disconnected	Not network-reachable during the offline period	Media and rotation policy dependent	Connection schedule can create a wider gap	Retrieval and staging can take longer	Media inventory, encryption key, reader availability, complete restore
Immutable copy	Resistance to deletion or modification within policy	Can still share site, storage, or identity dependencies	Read or control access may remain connected	Fixed retention scope	Depends on creation frequency	Depends on location and restore path	Retention lock, privileged paths, capacity, cleanliness, recoverability
Isolated cyber-recovery copy	Examination and staged recovery under restricted access	Designed outside ordinary production trust paths	Controlled transfer and recovery access	Needs enough points to predate intrusion	Selected clean point may be older than the latest copy	Analysis and validation usually add time	Provenance, malware and behavior analysis, identity review, application and business tests

Recommendation: Keep at least one recovery path outside the ordinary production administrative boundary. Separate the credentials and policy that can shorten retention, delete copies, change replication, or open the recovery network. Select the topology according to the organization's failure assumptions, administrative boundaries, recovery objectives, and operating capacity.

Treat Immutability as a Scoped Property

Ask four questions whenever a product or design uses the word *immutable*:

1. Which object is protected: snapshot, backup object, retention policy, catalog, metadata, or all of them?
2. For how long is it protected, and which event starts that period?
3. Which roles, support paths, keys, or administrative actions can alter or bypass the protection?
4. What happens when capacity fills, the control plane is unavailable, the clock is wrong, or the repository is moved?

An immutable point is not necessarily complete, application-consistent, readable, independent, or clean. Test those properties separately. Monitor attempts to disable protection, reduce retention, change time, remove a protection group, delete a repository, or alter the identities that control those actions.

Understand vSAN Data Protection Boundaries

VCF 9.1 can use vSAN Data Protection in supported designs, but its limits affect the recovery architecture:

- vSAN Data Protection is limited to vSAN Express Storage Architecture (ESA). Local snapshots remain on the source datastore.[37]

- Remote vSAN-to-vSAN replication requires a supported vSAN ESA target. VCF 9.1 expands some source-storage choices, but it does not make an arbitrary external array a vSAN snapshot target.[37]
- vSAN 9.1 includes a cyber-recovery health check for whether immutability is enabled on all protection groups in the cyber recovery cluster.[38] That setting does not prove a recovery point is clean or application-consistent.
- vSAN Data Protection 9.x does not provide multi-VM consistency or support shared VMDKs used by clustered virtual machines.[39] Use a supported application-aware or vendor recovery method for those workloads.
- Protection groups and snapshots are tied to cluster identity. Moving hosts or recreating a cluster can require protection-group and snapshot handling before the move.[40]

These details belong in workload classification. A single virtual machine with self-contained data may fit a VM-level snapshot policy. A clustered database with shared disks or coordinated writers may require a different protection and validation method.

Place the Recovery Control Plane Outside Its Own Failure

Backup catalogs, replication appliances, recovery orchestration, repositories, object stores, gateways, and scanners are privileged systems. They can read broad data sets and decide what survives. Design their identity, network, keys, logs, backups, and emergency access as carefully as the VCF management plane.

VCF Protection and Recovery is the current name for the service previously presented as VMware Live Recovery. It remains a separately licensed advanced service. In the 9.1 release train, disaster-recovery workflows move to a unified VCF Protection and Recovery appliance. The standalone Site Recovery Manager and vSphere Replication appliances are deprecated.[41] Follow the documented transition path for the starting version and configuration.

Cyber-recovery workflows can use an IRE to start candidate recovery points for analysis before workloads return to production.[42] Confirm the purchased entitlement, source and target support, retention, network requirements, inspection tools, and installed-build interoperability. Product analysis can reduce uncertainty. It does not guarantee that a candidate point is clean.

Recover the recovery control plane itself. Protect its configuration, catalog, certificates, keys, identity mappings, network rules, and copy inventory. Test access without the normal SSO path. A repository full of data is of limited use if the team cannot identify, decrypt, and restore the right objects.

For VCF instance recovery, Broadcom documents that infrastructure identifiers such as IP addresses and fully qualified domain names must match the source.[43] Treat that workflow as recovery, not as a general migration method. Validate the exact component and build coverage before relying on it for management-plane recovery.

Select a Recovery-Site Operating Pattern

Terms such as hot, warm, cold, and pilot light are useful only when the organization defines them. The following definitions focus on operating state rather than product names.

Pattern	Pre-Incident State	Likely Recovery Work	Cyber-Recovery Concern
Hot	Target capacity and service components are running, with current data replicated or synchronized	Select the recovery point, change network state, validate, and accept service	Persistent connectivity and current state can reproduce compromised identities, policy, data, or malware quickly.
Warm	Core target infrastructure runs, while some application components or capacity start during recovery	Start or scale services, select data, remap networks, and validate	Shared management, identity, keys, or orchestration may still connect the sites.

Pattern	Pre-Incident State	Likely Recovery Work	Cyber-Recovery Concern
Cold	Recovery copies exist, but most compute, platform, or application services are not running	Provision or recover infrastructure, restore data, configure networks, and validate	Longer recovery time and more manual steps increase execution risk, but fewer persistent paths may reduce ordinary attack reach.
Pilot light	A minimal, protected set of infrastructure and dependency services remains ready to expand	Add capacity, recover application tiers and data, open approved paths, and validate	The pilot light itself must be patched, monitored, isolated, and recoverable. Dormant does not mean trustworthy.

Continuous synchronization can help meet a disaster-recovery RPO. It can also copy deletion, encryption, malicious policy, or dormant persistence. Retain point-in-time history and give the response team authority to pause transfer when the suspected compromise outweighs the data-loss risk.

Build the Isolated Recovery Environment as an Operating Zone

An IRE is more than an unused VLAN. It needs controlled administration, inspection tools, dependency services, evidence storage, logging, and a path for approved updates or signatures. Candidate workloads should not trust production merely because they came from a production copy.

Design the IRE around these rules:

- Recovery-team identities are distinct from suspected production identities.
- Candidate systems begin with no production routes and only the minimum DNS, NTP, key, analysis, and management paths.
- Egress is blocked or mediated. Any access to update, reputation, or analysis services is logged and explicitly allowed.
- Scanners and analysis tools receive updates through a controlled path and are protected from candidate systems.
- Candidate systems cannot reach backup administration, hypervisor management, hardware controllers, or other recovery points unless the workflow requires it.
- All administrator actions and network changes are logged outside the candidate environment.
- The team can rebuild the IRE after it is used. Treat it as potentially exposed to whatever was recovered into it.

Limitation: Malware scanning is one input. Review accounts, startup items, scheduled tasks, services, remote-management tools, certificates, firewall policy, application changes, and known attacker activity. A clean scan alone is not return-to-service evidence.

Recover in an Order That Protects Trust

A practical cyber-recovery sequence is iterative. If evidence changes, return to scoping or choose an older point.

1. **Protect history.** Freeze unapproved retention and deletion changes. Confirm which copies remain and who can administer them.
2. **Establish clean administration.** Use controlled workstations, communications, credentials, MFA, and emergency accounts.
3. **Recover minimum infrastructure services.** Establish approved network control, DNS, time, identity, certificates, keys, logging, and recovery tooling in the recovery zone.
4. **Select candidate points.** Compare the intrusion timeline, provenance, integrity, application consistency, business data tolerance, and history depth.
5. **Recover into isolation.** Keep production routes closed. Use new or reviewed credentials and restricted service paths.
6. **Investigate and remediate.** Examine identity, persistence, binaries, configuration, data, network behavior, and control-plane history. Rebuild components when restoration would preserve uncertain state.

7. **Validate the dependency group.** Run technical, application, data, security, performance, and business checks. Reconcile transactions created after the selected point.
8. **Prepare production boundaries.** Patch, rotate credentials and secrets, review authorization, rebuild policy, and confirm monitoring before opening paths.
9. **Return in stages.** Open only the required dependencies and user paths. Monitor closely and retain the ability to contain again.
10. **Record the achieved outcome.** Capture the actual recovery point, elapsed recovery time, lost or reconciled data, exceptions, evidence, and approval.

The return-to-service decision should not belong to one technical team. Security accepts the residual compromise risk. The application and data owners accept application integrity and reconciliation. Infrastructure owners accept platform state. The business owner accepts service and data impact. Legal, privacy, communications, or regulatory owners may have separate obligations.

Validate the Recovery Method, Not Only the Restore Job

A successful job reports that a tool completed its work. It does not establish that users can transact safely. For each service, test:

- copy discovery when the ordinary catalog or SSO path is unavailable;
- decryption when the primary key provider or trust relationship is unavailable;
- recovery of vTPM-enabled and encrypted guests;
- application and database consistency, including clustered or shared-disk workloads;
- DNS, time, identity, certificate, load-balancer, and network dependencies;
- performance and capacity in the target environment;
- detection and containment inside the IRE;
- credential and secret rotation before production access;
- business transaction and data-reconciliation procedures; and
- staged return with enhanced monitoring and a tested rollback decision.

Decision record: State which copy types protect each service, who controls retention and deletion, and how much history is available. Identify the copy that is independent of production administration, the candidate-system examination zone, and the evidence required for return to service.

Test the Design

Test the assumptions that make the design different from an ordinary outage plan. A clean power failure and an orderly site failover do not exercise compromised credentials, hostile network paths, damaged recovery administration, or uncertain recovery points.

Use three kinds of exercise:

- A **tabletop** tests decisions, authority, communication, and missing information without changing production systems.
- A **technical exercise** tests a bounded mechanism, such as emergency sign-in, log retrieval, quarantine, key recovery, or isolated restore.
- A **service exercise** recovers and validates a dependency group under declared failure and compromise assumptions.

Run intrusive tests in an approved nonproduction or isolated environment unless the production change has been explicitly assessed and authorized. Define stop conditions, observers, evidence capture, and rollback before the test.

Scenario	Assumption to Exercise	Evidence of a Useful Result
Dependency loss	Primary DNS, NTP, certificate, key, logging, or identity service is unavailable	Operators identify the failure, use the approved alternate, preserve logs, and restore normal service without hidden manual dependencies
Identity outage	External identity provider or directory is unavailable	Named operators retrieve emergency access, reach every required control plane, and create an independent audit trail
Compromised administrator	A valid vCenter, NSX, identity, or backup administrator is suspected	Team scopes sessions and changes, revokes access, preserves history, establishes a clean administration path, and reviews resulting authorization
Workload quarantine	One application member is compromised	Network policy restricts it without capturing healthy recovery tools, and investigators retain approved DNS, time, logging, and analysis paths
Management-network containment	Production workload networks are hostile	Management, logging, keys, backup, and recovery remain reachable through designed paths
Backup-control-plane compromise	The catalog or ordinary backup administrator cannot be trusted	Team finds an independent copy, recovers required catalog or metadata, decrypts it, and performs a complete restore
Suspect latest replica	Recent replicated state may contain persistence	Team selects an earlier point using timeline and business criteria, starts it in isolation, and records data-reconciliation needs
Key-provider loss	The primary provider or trust relationship is unavailable	Team restores provider availability or uses protected recovery material and powers on encrypted and vTPM-enabled test guests
Isolated recovery	Production identity and network cannot be trusted	Recovery team builds the controlled zone, starts candidate services, updates analysis tools safely, validates dependencies, and stages return
Recovery-capacity shortage	Required target capacity is not immediately available	Owners prioritize services, expand the pilot light or cold site, and record the achieved recovery time and deferred workloads

For every exercise, record the installed builds, topology, starting state, test data, actions, observations, elapsed milestones, exceptions, and follow-up owners. A documented product capability is not a tested customer outcome until the deployed combination has been exercised.

Minimum Acceptance Tests

Before approving the design, demonstrate these results in the intended topology:

1. A named responder can administer essential VCF and recovery components without corporate SSO.
2. A responder can retrieve retained identity, platform, network, key, hardware, and backup evidence without relying on the suspected system.
3. A test workload can be quarantined while approved investigation and logging paths remain available.
4. A complete dependency group can start in a network with production routes closed.
5. An encrypted and vTPM-enabled test workload can recover after simulated loss of the ordinary key path.
6. The team can discover and restore a protected point without the ordinary backup administrator or primary catalog path.
7. Application and business owners can execute documented integrity and reconciliation checks.
8. The response owner can stage network reopening, monitor the restored service, and contain it again if new evidence appears.

Owner-Based Design Checklist

Use this checklist to find missing ownership. It is not a substitute for the current VCF Security Configuration Guide, product documentation, or an organization-specific control baseline.

Governance and Business Continuity Owners

- [ ] Define the ransomware scenarios and privileged identities the design must tolerate.
- [ ] Approve service priorities, disaster-recovery and cyber-recovery RTOs and RPOs, and acceptable data-reconciliation methods.
- [ ] Name the incident commander, evidence owner, recovery-point approver, and return-to-service authority.
- [ ] Fund enough independent capacity, copy history, staffing, and exercise time for the approved objectives.
- [ ] Record accepted shared dependencies and the consequence if each one fails.

Platform Team

- [ ] Record whether management and workloads are consolidated or separated and identify every remaining shared host, switch, storage, identity, key, and administration path.
- [ ] Maintain the approved firmware, TPM, Secure Boot, attestation, Lockdown Mode, driver, and patch state.
- [ ] Protect ESX configuration recovery keys and rehearse supported hardware-change recovery.
- [ ] Restrict and log vCenter, ESX, VCF Management Services, VCF Operations, and hardware-controller administration.
- [ ] Back up and test recovery of management components, configuration, certificates, and infrastructure identifiers.
- [ ] Confirm which updates qualify for Live Patch and which require evacuation, reboot, or planned downtime.

Network and Security-Policy Team

- [ ] Map management, vMotion, storage, overlay, workload, identity, key, logging, backup, recovery, and hardware-management flows.
- [ ] Use current installed-build data from the Broadcom Ports and Protocols tool to create allowlists.
- [ ] Identify the enforcement point and any bypass for each management, east-west, north-south, egress, and recovery path.
- [ ] Protect dynamic tag and security-group membership changes with authorization and alerting.
- [ ] Prepare tested quarantine and egress-restriction actions with rollback and required service exceptions.
- [ ] Validate physical link, switch, routing, LACP, beacon, and storage-multipathing failure behavior for the selected topology.

Identity Team

- [ ] Separate authentication ownership from VCF authorization approval where the risk warrants it.
- [ ] Apply supported phishing-resistant MFA and controlled administrative workstations to privileged access.
- [ ] Govern help-desk factor resets, account recovery, new authenticators, and privileged group changes.
- [ ] Maintain named emergency accounts and a credential-retrieval path that survives identity and network outages.
- [ ] Alert on unusual successful sign-ins, privilege changes, new API clients, MFA changes, and emergency access.
- [ ] Test provider loss, directory recovery, session revocation, and historical group-membership retrieval.

Core Infrastructure Services Team

- [ ] Protect and recover DNS zones, resolvers, delegations, signing keys, NTP configuration, certificate services, and trust stores.
- [ ] Provide monitored, diverse time sources to primary, recovery, and isolated environments.
- [ ] Remove circular dependencies among identity, DNS, keys, virtualization, storage, and backup systems.

- [ ] Document which dependency instance starts first and which credentials and network paths it requires.
- [ ] Test service recovery when the primary VCF environment is unavailable.

Key and Cryptography Owners

- [ ] Record the Native Key Provider or Standard Key Provider choice, protected objects, compliance requirement, and recovery owner.
- [ ] Back up Native Key Provider material before use and protect the PKCS#12 file and password separately.
- [ ] Back up Standard Key Provider configuration, keys, certificates, credentials, and trust-recovery procedures.
- [ ] Avoid placing every external KMS dependency inside the environment it unlocks.
- [ ] Test encrypted and vTPM-enabled workload recovery after key-provider and certificate loss.

Backup and Recovery Team

- [ ] Map each service to local points, remote points, replicas, backups, offline copies, immutable copies, or isolated recovery copies as required.
- [ ] Separate copy-retention and deletion authority from ordinary production administration.
- [ ] Record immutability scope, retention period, bypass paths, capacity behavior, and administrative dependencies.
- [ ] Protect and recover the catalog, orchestration configuration, certificates, keys, credentials, and copy inventory.
- [ ] Retain enough point history to investigate an intrusion that predates detection.
- [ ] Test complete restores, not only job completion, for application-consistent, clustered, encrypted, and vTPM-enabled workloads.
- [ ] Confirm vSAN ESA, target, multi-VM, shared-VMDK, cluster-identity, and installed-build support where vSAN Data Protection is used.
- [ ] Build and rehearse the IRE with production routes closed and independent recovery-team identities.

Security Operations and Incident Response Team

- [ ] Correlate successful identity activity with vCenter, ESX, NSX, workload, key, hardware, and backup changes.
- [ ] Retain logs outside the ordinary administrator's control for the required investigation period.
- [ ] Provide controlled workstations, communications, evidence storage, and response access independent of production identity.
- [ ] Define evidence-preservation steps and the authority for each containment action.
- [ ] Exercise a suspected privileged administrator, not only guest malware.
- [ ] Define the security evidence required to accept a candidate recovery point and return it to service.

Application and Data Owners

- [ ] Document service dependencies, startup order, consistency method, business transaction checks, and data reconciliation.
- [ ] Approve observed network flows and narrow management, ingress, egress, and service-to-service policy.
- [ ] Protect templates, images, automation, packages, configuration, secrets, and publisher identities.
- [ ] Select a supported protection method for clustered applications, shared disks, and coordinated writers.
- [ ] Test the complete service in isolation, including degraded and substituted dependency modes.
- [ ] Approve application integrity, data state, exceptions, and staged return to service.

Glossary

Air gap: A colloquial term for separation. State whether the design uses physical isolation, logical isolation, offline media, or controlled connection windows instead.

Cyber recovery: Recovery performed when production systems, identities, networks, or recent copies may be compromised. It adds protected history, investigation, controlled administration, isolated validation, and staged return to service to ordinary restore work.

Dependency group: The application components and supporting services that must recover in a coordinated order for a business service to work.

Disaster recovery: Recovery of service after a site or infrastructure failure, commonly through replication, recovery plans, and target-site activation. It does not by itself establish that the recovered state is free of compromise.

Emergency access: A restricted, monitored administrative path used when the normal identity or management path is unavailable. It is often called break-glass access.

Immutable copy: A copy that resists modification or deletion for a defined time and administrative scope. Immutability does not prove cleanliness or recoverability.

Isolated recovery environment (IRE): A controlled network and tool set used to start, inspect, remediate, and validate candidate recovery points before production connectivity is restored.

Logical isolation: Separation created by enforced configuration, such as routing, firewall policy, access control, credentials, or restricted endpoints, on connected systems.

Offline copy: A copy that is not network-accessible during normal operation. Its connection, administration, encryption, storage, and test procedures remain part of the design.

Phishing-resistant MFA: Multifactor authentication designed to resist credential replay and verifier impersonation. Availability depends on the chosen identity provider, authenticator, client, and product path.

Recovery point objective (RPO): The point in time to which data must be recoverable, reflecting the amount of data loss the organization can tolerate.

Recovery time objective (RTO): The maximum time a system resource can remain unavailable before its effect becomes unacceptable.

Survivable access: An approved administrative path that remains usable under the outage or compromise assumptions for which it was designed.

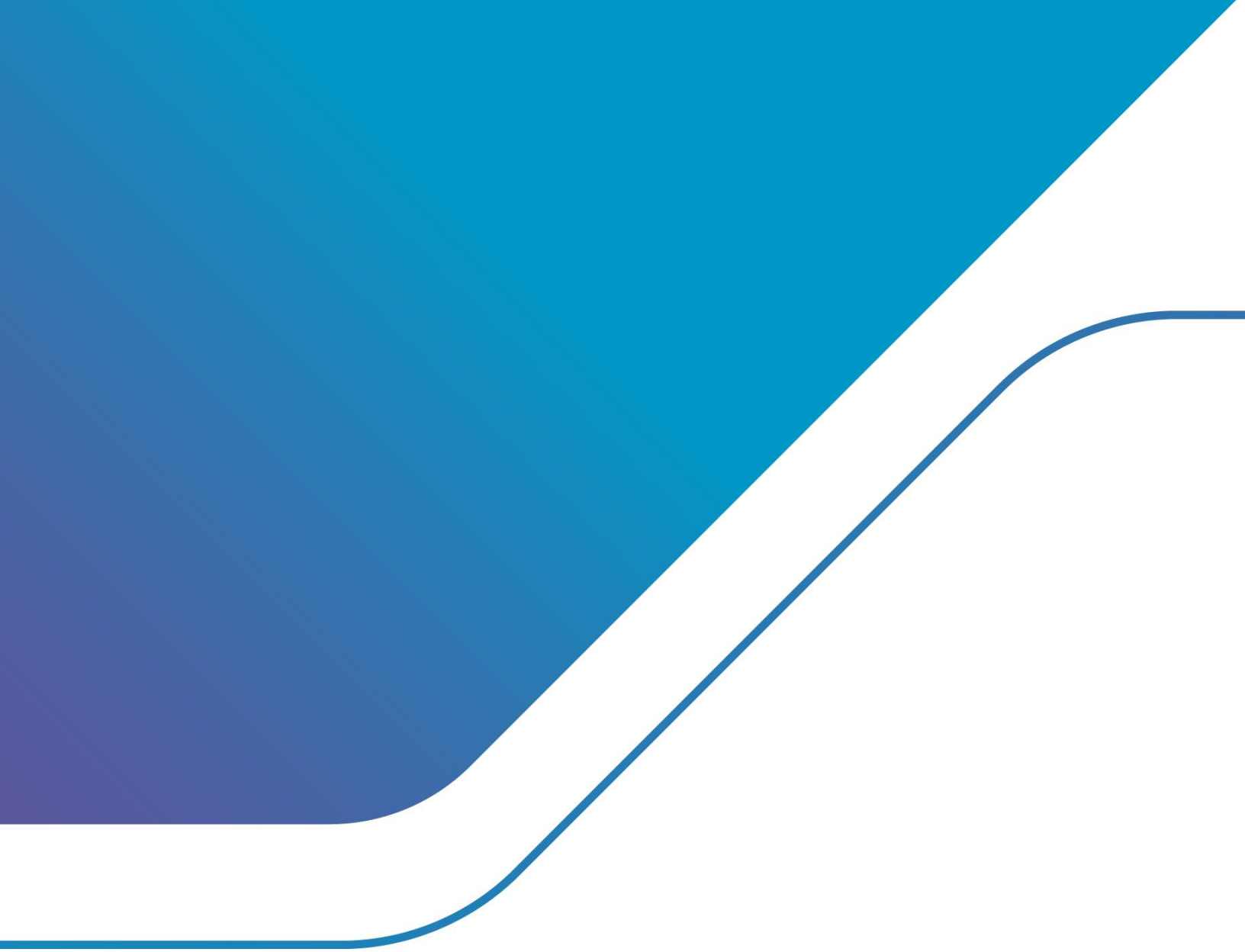
Zero Trust: An access model that grants no implicit trust solely because of network location or asset ownership and requires authentication and authorization before resource access.

Notes and Sources

Product documentation and knowledge-base articles are mutable. The links below were checked on August 28, 2026. Confirm installed-build behavior, interoperability, and entitlement before implementation.

1. National Institute of Standards and Technology, NIST IR 8374 Revision 1, *Ransomware Risk Management: A Cybersecurity Framework 2.0 Community Profile*, June 2026. The original IR 8374 was withdrawn June 11, 2026.
2. Cybersecurity and Infrastructure Security Agency, Federal Bureau of Investigation, and Department of Health and Human Services, AA22-321A, *#StopRansomware: Hive Ransomware*, November 17, 2022.
3. Cybersecurity and Infrastructure Security Agency and Federal Bureau of Investigation, AA23-039A, *ESXiArgs Ransomware Virtual Machine Recovery Guidance*, February 9, 2023.
4. Broadcom, *VMware Cloud Foundation 9.1 Release Notes*, VCF 9.1, checked August 26, 2026.
5. Broadcom, *Security and Compliance*, VCF 9.1, checked August 26, 2026. Select the security configuration guide for the installed VCF release.
6. Broadcom, *VMware Cloud Foundation 9.1 General FAQs*, May 28, 2026.
7. Broadcom, KB 426655, *Build numbers and versions of VCF Protection and Recovery (formally VMware Live Recovery)*, checked August 26, 2026.
8. Cybersecurity and Infrastructure Security Agency, *#StopRansomware Guide*, revised October 19, 2023.
9. Federal Bureau of Investigation Internet Crime Complaint Center, *Cyber Criminals Target Victims Using Social Engineering Techniques*, April 11, 2024.
10. Federal Bureau of Investigation Internet Crime Complaint Center, *Criminals Use Generative Artificial Intelligence to Facilitate Financial Fraud*, December 3, 2024.
11. Australian Signals Directorate's Australian Cyber Security Centre and partner agencies, *Five Eyes Cyber Security Agencies Statement on AI and Cyber Threats*, June 22, 2026.
12. National Institute of Standards and Technology, NIST SP 800-207, *Zero Trust Architecture*, August 2020.
13. Broadcom, *VMware Cloud Foundation: A Technical Overview*, checked August 26, 2026.
14. National Institute of Standards and Technology, NIST SP 800-193, *Platform Firmware Resiliency Guidelines*, May 2018.
15. Broadcom, KB 369525, *"Host TPM attestation alarm" in vSphere Client for ESXi Hosts*, checked August 26, 2026.
16. Broadcom, KB 312109, *ESXi boot failures due to system configuration issues - restore security configuration, decrypt system configuration, recover system configuration*, checked August 26, 2026.
17. Broadcom, KB 336894, *Enabling or Disabling Lockdown Mode on an ESXi Host*, checked August 26, 2026.
18. Broadcom, *Strengthen Zero Trust Security and Resilience with VCF 9.1*, May 5, 2026.
19. Broadcom, *Live Patch Gets Even Better in vSphere with VMware Cloud Foundation 9.0*, July 15, 2025, updated with ESX 9.1 behavior.
20. Broadcom, KB 399001, *Check for Planned Downtime resulting from Reduced Downtime Upgrade (RDU) usage*, checked August 26, 2026.
21. Broadcom, *VMware Ports and Protocols*, checked August 26, 2026.
22. Broadcom, *VCF Secure and Resilient Platform Solution Brief*, checked August 26, 2026.
23. Broadcom, *Avi Load Balancer Design Guide for vSphere*, checked August 26, 2026.
24. Broadcom, KB 389732, *Introduction to LACP in VMware by Broadcom*, checked August 26, 2026.

25. Broadcom, KB 324536, *What Is Beacon Probing?*, updated March 18, 2025.
26. Internet Engineering Task Force, RFC 4033, *DNS Security Introduction and Requirements*, March 2005.
27. Internet Engineering Task Force, RFC 8633, *Network Time Protocol Best Current Practices*, July 2019.
28. Broadcom, KB 440630, *Upgrade Sequence and Related Issues for VMware Cloud Foundation and vSphere Foundation 9.1*, VCF 9.1, checked August 26, 2026.
29. Broadcom, KB 443088, *Log Management menus for SSO and password settings missing after upgrade to VCF 9.1*, checked August 26, 2026.
30. Broadcom, KB 443999, *Virtual Machine Locked Alarm*, checked August 26, 2026.
31. Broadcom, KB 396471, *Configure vSphere Native Key Provider*, checked August 26, 2026.
32. Broadcom, KB 396741, *Re-establishing Trust between vCenter and KMS cluster after certificate replacement*, checked August 26, 2026.
33. Broadcom, KB 377302, *Windows 11 or Windows Server virtual machine fails to boot with error "The virtual machine must be encrypted."*, checked August 26, 2026.
34. National Institute of Standards and Technology, NIST SP 800-34 Revision 1, *Contingency Planning Guide for Federal Information Systems*, May 2010, pages 11 and 47.
35. Microsoft, *Active Directory Forest Recovery Guide*, updated July 11, 2025.
36. Broadcom, *Implement Ransomware Protection and Recovery Service Brief*, checked August 26, 2026.
37. Broadcom, KB 433469, *vSAN Data Protection Support for vSAN OSA and External Storage Arrays*, checked August 26, 2026.
38. Broadcom, KB 424480, *vSAN Data Protection - General - vSAN Snapshots Immutability Check*, VCF 9.1.
39. Broadcom, KB 416514, *vSAN Data Protection snapshot fails on cluster VMs with shared disk/disks*, checked August 26, 2026.
40. Broadcom, KB 447365, *Error: Duplicated key not allowed when creating local vSAN Data Protection group after cluster creation / migration*, checked August 26, 2026.
41. Broadcom, KB 444864, *VCF Protection and Recovery 9.1: Transition from standalone SRM and VR 9.0.2*, VCF Protection and Recovery 9.1.
42. Broadcom, *Cyber Protection and Recovery for VMware Cloud Foundation*, checked August 26, 2026.
43. Broadcom, KB 439975, *VCF Instance Recovery to Environment with Different IP/FQDN is Not Supported*, checked August 26, 2026.



vmware® by Broadcom

Copyright © 2026 Broadcom. All rights reserved.
The term "Broadcom" refers to Broadcom Inc. and/or its subsidiaries. For more information, go to www.broadcom.com. All trademarks, trade names, service marks, and logos referenced herein belong to their respective companies. Broadcom reserves the right to make changes without further notice to any products or data herein to improve reliability, function, or design. Information furnished by Broadcom is believed to be accurate and reliable. However, Broadcom does not assume any liability arising out of the application or use of this information, nor the application or use of any product or circuit described herein, neither does it convey any license under its patent rights nor the rights of others.